

Information Security Governance in Action

GlobalHealth Connect (GHC) — Executive Governance Simulation

Course	GRC102 – Information Security Governance
Practical	Week 1 Practical Laboratory
Student	Imelda Sanya
Registration Number	C11/26/CGRCE/17576

Executive Summary

GlobalHealth Connect (GHC) has reached a point where its previous ad-hoc security approach is no longer suitable for a growing health-technology organisation. Rapid growth, two acquisitions and a contained data-leakage near-miss have exposed weaknesses in ownership, policy consistency, risk management and executive reporting. The recommended response is to establish a clear governance structure led by executive accountability, supported by a cross-functional Security Steering Committee (SSC), a formal Information Security Charter and a defined risk-and-metrics cycle.

The six-month security dataset also indicates a deteriorating risk posture. Phishing attempts increased from 150 to 320, malware events from 25 to 50, and high-risk incidents from 2 to 7. At the same time, critical-vulnerability patching fell from 67% to 55%, leaving 18 of 40 critical vulnerabilities unpatched in February. Training completion improved from 45% to 70%, which is positive, but the overall trend remains concerning because threat activity and high-risk outcomes are increasing while a key technical control is weakening.

Evidence Bundle 1 — Governance Blueprint

Evidence 1 — Current-State Governance Gap Assessment

Gap	Current weakness	Priority	Governance response
Unclear security ownership	Security activities are distributed across IT, Compliance, HR, Development, Finance/Data and business owners without a single governance accountability model.	High	Establish a Security Governance function, named risk owners and RACI.
No formal governance forum	Cross-functional security decisions can be handled informally, making prioritisation and escalation inconsistent.	High	Create the Security Steering Committee with defined authority and cadence.
Inconsistent policies	Policies inherited through acquisitions are inconsistent and not always current.	High	Introduce policy ownership, review dates, approval workflow and exception management.
Reactive risk management	The scenario describes a reactive approach rather than a formal proactive assessment process.	High	Create a risk register, regular risk reviews and treatment tracking.
Weak business translation of metrics	Technical measures exist but are not consistently translated into business impact.	Medium	Use Board metrics tied to customer trust, availability, risk exposure and remediation.

Low training engagement	Annual training is mandatory but engagement is low.	Medium	Move toward role-based awareness and effectiveness measures, not completion alone.
-------------------------	---	--------	--

Evidence 2 — Proposed Security Governance Organisational Chart

BOARD OF DIRECTORS		
Sarah Chen — CEO / Executive Management		
SECURITY STEERING COMMITTEE (SSC)		
Director of Information Security Governance		
CTO / IT Operations John Smith	Governance, Risk & Assurance Compliance / Legal	Business & People Functions Development • HR • Finance/Data

The Board provides oversight; the CEO owns executive accountability; the SSC provides cross-functional prioritisation and decision support; and the Information Security Governance function coordinates policy, risk, metrics and escalation. Technical, compliance and business functions retain ownership of the risks and controls within their areas.

Evidence 3 — RACI Responsibility Matrix

Activity	CEO	Security Governance	CTO / IT	Compliance	Business / HR / Data
Policy approval	A	R	C	C	C
Risk review	A	R	C	C	R
Incident response planning	A	R	R	C	C
Security awareness	I	A	C	C	R
Third-party security review	A	R	C	C	R
Security metrics / Board reporting	A	R	C	C	I
Security exceptions / risk acceptance	A	R	C	C	R
Governance maturity review	A	R	C	C	C

R = Responsible; A = Accountable; C = Consulted; I = Informed. The matrix deliberately separates accountability from execution so that decisions do not become ownerless.

Evidence 4 — Governance Rationale

- Accountability: each material governance activity has an accountable executive and an identified responsible function.
- Transparency: the SSC creates a repeatable forum for decisions, actions, risk acceptance and escalation.
- Business alignment: security priorities are evaluated against growth, uptime, customer trust, innovation and compliance objectives rather than treated as isolated technical tasks.
- Risk management: a formal risk-review cycle and named owners move GHC from reactive response toward proactive management. This is consistent with NIST CSF 2.0, which places governance, roles, responsibilities, policy and oversight at the centre of cybersecurity risk management.

Evidence Bundle 2 — Information Security Charter

Evidence 5 — GHC Information Security Charter

1. Purpose

The GHC Information Security Programme protects patient and organisational information, supports reliable digital services, enables secure innovation and manages information-security risk in a way that supports GHC's strategic objectives.

2. Scope

The Charter applies to employees, contractors, third parties and relevant business partners; cloud services and infrastructure; applications and development environments; patient, financial and business information; endpoints and other information assets; and the policies, risk processes, assurance activities and security operations used to protect them.

3. Authority

The programme operates under executive management authority with Board oversight. The Director of Information Security Governance is authorised to coordinate security governance, require appropriate risk evidence, escalate material risks and recommend corrective action. Business and system owners remain accountable for the risks arising from assets and activities under their control.

4. Roles and Responsibilities

The CEO provides executive sponsorship and makes or escalates major risk decisions. The Director of Information Security Governance coordinates governance, policy, risk, reporting and assurance. The CTO and IT Operations manage technical implementation and operational resilience. Compliance/Legal advises on applicable obligations. HR supports workforce security and lifecycle controls. Business, data and system owners own operational risks and control responsibilities.

5. Key Principles

Risk-based; business-aligned; proportionate; accountable; evidence-led; secure by design; and continuously improving.

6. Reporting Structure

The SSC reviews material security risks, metrics, exceptions and improvement actions at least monthly. Material incidents, significant risk acceptance decisions and unresolved high risks are escalated to executive management and, where appropriate, the Board. A concise security dashboard is provided to the Board at least quarterly.

7. Review and Approval

The Charter is reviewed at least annually and after significant organisational, regulatory, technology or risk changes. Material amendments require executive approval and Board visibility. Supporting policies and standards must have named owners and defined review dates.

Governance reference

NIST CSF 2.0 identifies governance activities such as risk strategy, roles and responsibilities, policy and oversight as core elements of managing cybersecurity risk. For a healthcare technology organisation, applicable healthcare obligations should also be reflected in the programme. HHS describes the HIPAA Security Rule as requiring appropriate administrative, physical and technical safeguards for ePHI where the organisation is a regulated entity.

Evidence 6 — Justification Memo to Marcus Thorne, CFO

To: Marcus Thorne, Chief Financial Officer

From: Director of Information Security Governance

Subject: Business case for the GHC Information Security Charter

The Charter gives GHC a practical governance mechanism for making security investment decisions against business priorities. By assigning accountability, setting escalation routes and requiring evidence-based risk review, it helps management decide where investment is most important rather than treating security spend as a collection of disconnected technical requests. This directly supports GHC's plan to grow the client base by 25%, enter two regional markets and improve operational efficiency while protecting the trust on which those goals depend.

The Charter also addresses the governance risk created by acquisitions and inconsistent practices. A common mandate, ownership model and reporting cycle gives management a basis for comparing risks and deciding when remediation, acceptance or additional investment is appropriate. The approach is intended to reduce avoidable disruption, protect patient information and support secure innovation while maintaining a clear link between security activity and enterprise risk.

Evidence Bundle 3 — Board Reporting and Security Metrics

Evidence 7 — Board Executive Summary

BOARD POSTURE: RED

The six-month trend shows increasing threat activity, increasing high-risk incidents and declining critical-vulnerability patching. Training completion is improving, but it has not yet translated into an improved overall risk trend. Immediate management attention is required.

Board-level interpretation: GHC's exposure is moving in the wrong direction. Phishing and malware counts have doubled across the period, high-risk incidents have increased more than threefold, and the proportion of critical vulnerabilities patched has fallen. The organisation should therefore prioritise remediation ownership, faster treatment of critical vulnerabilities and analysis of the causes behind repeated high-risk incidents. Training should continue, but effectiveness should be assessed alongside completion.

Evidence 8 — Five Selected Security Metrics

Metric	Current status	Six-month trend	Signal	Board commentary
Phishing events	320 in Feb	150 → 320 (↑ 113%)	Rising	Increasing social-engineering exposure can drive account compromise and operational disruption. Targeted awareness and email/identity controls should be reviewed.
Malware events	50 in Feb	25 → 50 (↑ 100%)	Rising	Doubling indicates increasing endpoint exposure. Management should track root causes, affected assets and control effectiveness.
Critical vulnerabilities patched	22 of 40 (55%)	67% → 55% (↓ 12 pp)	Worsening	18 critical vulnerabilities remained unpatched in February. Ownership, deadlines and escalation are needed.
Training completion	70% in Feb	45% → 70% (↑ 25 pp)	Improving	Positive control activity, but completion alone does not prove reduced risky behaviour. Effectiveness measures should be added.
High-risk incidents	7 in Feb	2 → 7 (↑ 250%)	Worsening	Increasing severe outcomes are the strongest signal that the overall risk posture remains RED.

Evidence 9 — Priority Risks and Actionable Recommendations

Priority issue	Why it matters	Recommended action
Critical vulnerability backlog	18 of 40 critical vulnerabilities were unpatched in February and patching fell to 55%.	1) Assign an owner to every critical vulnerability. 2) Set remediation deadlines by risk. 3) Escalate overdue items through the SSC. 4) Report aged critical backlog to the Board.
Rising high-risk incidents	High-risk incidents increased from 2 to 7 while phishing and malware also rose.	1) Conduct monthly root-cause and recurrence analysis. 2) Prioritise controls against the dominant causes. 3) Track repeat incidents and time to containment. 4) Escalate unresolved systemic issues.

Increasing phishing / malware	Phishing and malware counts both doubled, increasing the likelihood of compromise and disruption.	1) Run targeted awareness based on observed behaviours. 2) Review email and identity controls. 3) Strengthen endpoint prevention/detection where evidence indicates gaps. 4) Measure repeat-user risk.
-------------------------------	---	--

Evidence 10 — Metric Selection Rationale

The five metrics provide a balanced Board view across exposure, control performance and outcomes. Phishing and malware represent changing threat exposure; vulnerability patching shows whether a critical preventive control is being executed; training completion measures a people-control activity; and high-risk incidents provide an outcome measure. Together, they allow the Board to see not only whether activity is occurring, but whether risk indicators and security outcomes are improving.

Evidence Bundle 4 — Security Steering Committee

Evidence 11 — Security Steering Committee Terms of Reference

Purpose

Provide a cross-functional governance forum for security risk, prioritisation, policy decisions, exceptions, major incidents and improvement initiatives.

Scope

Information-security policies and standards; enterprise security risks; major incident readiness and lessons; security exceptions; third-party risk; Board metrics; governance maturity; and security investment priorities.

Membership

CEO or delegated executive sponsor; Director of Information Security Governance; CTO; IT Manager; Compliance Officer; Senior Developer; HR Manager; Finance/Data representative. Subject-matter experts may attend when required.

Responsibilities

Review material risks; monitor remediation; resolve cross-functional conflicts; review security metrics; recommend or approve policy decisions within delegated authority; oversee governance improvement; and escalate matters that exceed delegated risk or financial thresholds.

Meeting cadence

Monthly as the standard governance cycle, with extraordinary meetings for major incidents, urgent risks or time-sensitive decisions.

Decision authority

The SSC may make decisions within authority delegated by executive management. Decisions involving material risk acceptance, significant financial exposure or matters outside delegated authority are escalated to the CEO/executive management and, where appropriate, the Board.

Reporting

Maintain minutes, decisions, actions, owners and due dates. Material unresolved risks and escalations are included in executive/Board reporting.

Password Policy Recommendation

The current proposal requires 16-character complex passwords changed every 30 days without password-manager integration. The CTO proposes a more balanced approach centred on multi-factor authentication and secure password management. The recommended governance position is to prioritise strong MFA, long unique passwords, secure password-manager support and stronger controls for privileged or sensitive accounts, while avoiding blanket frequent password changes unless a risk assessment or incident justifies them. This approach reduces user friction while retaining strong authentication assurance and gives the SSC a clearer basis for deciding where additional controls are necessary.

Evidence 12 — First SSC Meeting Agenda

#	Agenda item	Lead	Time
1	Opening and confirmation of objectives	CEO / Chair	5 min
2	Near-miss lessons and current governance gaps	Security Governance	10 min
3	Password-policy conflict and recommendation	CTO + IT Manager	20 min
4	Critical-vulnerability backlog and remediation ownership	IT / Security Governance	10 min
5	Board metrics and RED posture	Security Governance	10 min
6	Information Security Charter / policy lifecycle	Security Governance + Compliance	10 min
7	Actions, owners, due dates and escalations	Chair	10 min

Evidence 13 — Briefing Note to Sarah Chen, CEO

The SSC gives GHC a repeatable way to resolve disagreements that cross technical, operational and business boundaries. Instead of allowing the password-policy dispute to be decided solely by the strongest technical position or the strongest productivity concern, the Committee can compare the risk, user impact, cost, control effectiveness and business context before recommending a decision. The proposed membership ensures that technology, security governance, compliance, people and business perspectives are considered together.

The SSC also creates an escalation path for issues that cannot be resolved at working level. Decisions should be documented with the rationale, owner and review point, while material risks or exceptions should be escalated to executive management and the Board where appropriate. This supports strategic alignment because security decisions become part of normal enterprise governance rather than separate technical disputes.

Evidence Bundle 5 — Governance Maturity Assessment

Evidence 14 — Current Maturity Assessment

Domain	Level	Evidence basis	Priority improvement
Policy & Documentation	2 — Initial	Policies exist but are inconsistent, inherited through acquisitions and not always current.	Create ownership, review dates and a controlled policy lifecycle.
Roles & Responsibilities	1 — Ad Hoc	Security ownership and accountability are unclear.	Approve governance structure, RACI and named owners.
Risk Management	1 — Ad Hoc	The organisation is reactive and lacks a formal proactive assessment process.	Establish risk register, assessment cadence, treatment tracking and escalation.
Metrics & Reporting	2 — Initial	Technical metrics exist but are not consistently translated into business impact.	Define Board KPIs/KRIs and connect metrics to decisions and risk.
Training & Awareness	2 — Initial	Annual mandatory training exists but engagement is low.	Introduce role-based learning and effectiveness measures.
Compliance	2 — Initial	Compliance preparation is audit-driven rather than continuously monitored.	Create continuous evidence, control monitoring and review routines.

Overall current maturity: Level 2 — Initial

The overall assessment is Level 2 because several processes exist, but they are inconsistently documented or applied. Roles & Responsibilities and Risk Management are currently Level 1 and therefore constrain the reliability of the wider governance system. The 12–18 month target is Level 3 — Defined across all six domains.

Evidence 15 — 12–18 Month Maturity Roadmap

Initiative	Timing	Objective / key activities	Measurable expected outcome
1. Governance foundation	Months 1–3	Approve Charter; establish SSC; finalise RACI; define escalation and decision rights.	All core governance activities have named owners; SSC meets monthly; material escalations are documented.
2. Policy and risk baseline	Months 2–6	Review inherited policies; assign owners; establish review cycle; build risk register; conduct proactive assessments.	Core policies have owners/review dates; material risks have owners, treatment and due dates.
3. Board metrics and assurance	Months 4–9	Define KPIs/KRIs; build Board dashboard; establish quarterly reporting; track assurance actions.	Quarterly Board reporting is consistent and actions are tracked to closure.
4. People and control effectiveness	Months 6–12	Introduce role-based awareness; targeted phishing education; strengthen onboarding/offboarding controls; measure effectiveness.	Training reaches at least 90% completion and repeat risky behaviour shows a measurable downward trend.
5. Continuous compliance and	Months 9–18	Create evidence repository; monitor controls; conduct internal reviews; track	Control reviews occur routinely, evidence is readily available

improvement		corrective actions; refresh risk assessments.	and overdue findings reduce over time.
-------------	--	---	--

Evidence 16 — Board Executive Summary

GHC is currently at an overall Level 2 — Initial maturity, with Roles & Responsibilities and Risk Management at Level 1. This means the organisation has some security practices, but they are not yet consistently governed, documented or applied. The gap is strategically significant because GHC is simultaneously expanding its client base, integrating acquisitions, pursuing regional growth and investing in AI-driven healthcare capabilities. Growth without stronger governance could increase operational and regulatory exposure.

The roadmap therefore starts with governance foundations and risk ownership, then moves into policy consistency, Board reporting, workforce effectiveness and continuous compliance. The target is Level 3 — Defined across all domains within 12–18 months. Reaching Level 3 will not mean that risk disappears; it will mean that GHC has documented, standardised and accountable processes that management can monitor and improve.

Conclusion

The GHC scenario demonstrates why information security governance must connect people, decisions, risk and business outcomes. The proposed governance blueprint establishes accountability through a clear reporting structure and RACI model. The Charter formalises authority and scope, while the SSC creates a practical mechanism for cross-functional decisions and escalation. Board reporting translates the supplied security data into a clear RED posture and prioritises the risks that require management action.

The maturity roadmap provides a realistic sequence for moving GHC from a reactive and inconsistent programme toward defined governance within 12–18 months. The approach is designed to support, rather than obstruct, GHC's strategic goals: growth, efficiency, customer trust, innovation and regulatory readiness.

References

- National Institute of Standards and Technology. (2024). The NIST Cybersecurity Framework (CSF) 2.0 (NIST CSWP 29). U.S. Department of Commerce. <https://doi.org/10.6028/NIST.CSWP.29>
- U.S. Department of Health and Human Services, Office for Civil Rights. (2026). Summary of the HIPAA Security Rule. <https://www.hhs.gov/hipaa/for-professionals/security/laws-regulations/index.html>
- U.S. Department of Health and Human Services, Office for Civil Rights. (2026). Guidance on Risk Analysis. <https://www.hhs.gov/hipaa/for-professionals/security/guidance/guidance-risk-analysis/index.html>